Security Architecture Task 5 Group Presentation Script

WinLocal Security & NIST CSF 2.0

Signposting / Introduction [Joseph – 45s]

Hi everyone. Today, we are here to discuss WinLocal Giveaways' current cybersecurity situation and infrastructure.

WinLocal has experienced fantastic growth in recent times, expanding beyond Dublin and seeing increased site traffic. However, a recent ransomware incident has shown that your web infrastructure has not scaled securely along side the growth of your business.

The roadmap: We will break down this presentation into the following sections:

I will discuss the key security risks that have been experienced.
Mael will explain where these risks lay within the globally recognized NIST Cybersecurity Framework.
And Mark discusses a clear path forward to protect your customer data and ensure your website stays online and explain some of our findings.

Key Security Risks [Joseph – 1m15s]

Risk 1: Flat Network & Lateral Movement. At present, the network layer lacks segmentation – the attackers who breached the web application were easily able to move laterally and compromise the stored data.

Risk 2: Prolonged Undetected Breaches. The attackers had access to internal systems for 10 weeks, secretly exploring and extracting sensitive customer data.

Risk 3: Weak Access Controls & Human Error. Currently, system access is managed on an unplanned and specific use, "ad-hoc", basis. This, combined with a lack of cyber security awareness and training with your staff lead to weak passwords and phishing susceptibility - ultimately making the initial compromise possible.

Risk 4: And lastly, Availability & Outdated Infrastructure. The current load balancer, which distributes network traffic across the resources is unsupported meaning that scaling requires manual intervention. This has lead to outages during peak promotional campaigns.

Mael?

Mapping Issues to NIST CSF 2.0 [Maël – 2m]

1. Govern: The start-up lacks a formal approach to risk management, and there is no structured cybersecurity training for staff. Access to systems is also currently handled ad-hoc (as mentioned).
2. Identify: There is an inability to proactively identify and mitigate threats before they happen, and a lack of visibility into where critical customer data resides across the network.
3. Protect: Customer data is inadequately safeguarded due to a flat network architecture and poor password practices.
4. Detect: Malicious actors were able to navigate the system for ten weeks without triggering any internal alarms.
5. Respond: The breach was only discovered by accident during an unrelated availability outage, highlighting a severe delay in incident response capabilities.
6. Recover: Recovering from high traffic or outages requires manual server provisioning, and database storage issues result in complete loss of access to competition data.

Now onto Mark with recommendations.

Recommendations / Security Controls & Strategies [Mark – 1m15s]

Govern & Identify: Establish clear security policies, including a mandatory awareness program for staff to combat phishing and social engineering attacks. Implement Role-Based Access Control (RBAC) and conduct routine risk assessments to find vulnerabilities early.

Protect & Detect: Implement strict network segmentation using the AWS architecture proposed in our report, as seen in this simplified diagram. This shields the stored data (databases) from the servers' (web) layer. We will also deploy continuous monitoring and logging tools to flag anomalous behaviour immediately.

Respond & Recover: Develop an automated Incident Response Plan. We will utilize automated backups and the automatic scaling of the servers, so the platform handles traffic spikes independently, ensuring it is nearly constantly available (known as five nines).

Findings [Mark – 45s]

WinLocal's current on-premises architecture is holding the business back, creating operational bottlenecks and critical security liabilities.

A "Secure-by-Design" cloud migration is not just an IT upgrade; it is a business necessity to protect the company's reputation and customer trust.

Technology alone won't solve the problem. Fostering a culture of security awareness among the staff is just as critical as the firewalls protecting the servers.

Now, onto Maël with conclusions.

Key Takeaways / Conclusion [Maël – 30s]

Security constantly shifts, it's never static. By adopting the NIST CSF 2.0, WinLocal Giveaways gains a practical, scalable framework to understand its posture and communicate risks clearly.

The proposed cloud migration paired with this framework will significantly reduce the likelihood of future attacks, ensure availability during peak competitions, and greatly support WinLocal Giveaway's expansion.

Thank you for your time.